

国际的
标准

ISO/IEC
27007

第三版
2020-01

信息安全、网络安全和隐私保护——信息
安全管理系统审计指南

信息安全、网络安全和对隐私权的保护——信息安全管理系统的审
计指导

ISO IEC
Xictz I-----•

参考编号
ISO/IEC 27007:2020(E)

©ISO/IEC 2020

版权保护文件

5 © ISO/IEC 2020
沙迦保留所有权利。除非另有规定，或在其实实施过程中提出要求，本出版物的任何部分不得
> 以任何形式或任何电子或机械方式复制或使⤵用，包括复印或张贴？未经事先书面许可，进入互联网或内部网。可以向以下地址 I 的 ISO 或请求者所
在国的 ISO 成员机构申请许可
?ISO 版权局
> CP 401 • Ch. 布线网 8
! 日内瓦游标 CH-1214
I 电话： +41 22 749 01 11
J Fax: +41 22 749 09 47
?电子邮件： copyright@iso.org
)网站： www.iso.org
在瑞士出版

内容

页

前言

介绍

vi

范围

2

规范性引用文件

3

术语和定义

4

审计原则

5

管理审计计划

5.1 范围 1.....

5.2 建立审计计划的目标

5.3

确定和评估审计计划的风险和机会

5.4

建立审计计划管理审计方案的角色和职责：个人管理审计方案的能力

5.4.1 确定审计方案的范围.....确定审计计划的资源.....

5.4.2

5.4.3

...

5.5

5.4.4

.....

实施审计方案

定义个别审计的目标、范围和标准，选择和确定审计方法

.. 4

5.5.1 选择审核团队成员.....

.....

5.5.2将个别审核的责任分配给审核小组组

... 4

5.5.3

长，管理审核计划的结果。

.....

5.5.4 管理和维护审计计划记录

.. 4

5.5.5

5.6

5.5.6

.....

5.7

5.5.7

. 5

监测审计方案

进行审计

审核和改进审计方案.....

.....

6.1

将方案

.....

6.2

5

6.2.2 与被听方建立联系

.....

6.2.3

确定审计的可行性

5

6.3

准备审计活动

.....

6.3.1 执行对文件化信息的审核，审核计划

... 5

6.3.2 向审核团队分配工作

6.3.3 准备可供审核使用的文件化信息

Z. 5

6.4

6.3.4

开展审计活动

6.4.1

6.4.2 分配主持开幕会议的导游和观察员的角色和职责

.....

6.4.3

在审计期间可以使用硬币

.....

6.4.4

6.4.5

6.4.6 审核信息的可用性和访问权限

6

6.4.7

6.4.8 收集和验证信息

... 6

6.4.9

6.4.10

生成审计结果

6

6.5

编制和分发审计报告

6

6.5.1 编制审计报告

6

6.6

6.5.2 分发审计报告

6

6.7

进行审计跟踪

iit

7. 审计师的能力和评价		
7.1 将军-----		0
7.2 确定审计员能力		3
7.2.1 将军-----		0
		0
7.2.3 oedge ar^d		0
7.2.4 实现审计能力		3
7.2.5 实现审计团队领导的能力		3
		3
7.3 建立审计师的评估标准。。。。。。		3
7.4 选择合适的审计师评估方法		3
7.5 进行审计师评估.....		
7.6 保持和提高审计师的能力		
附件 A（信息性）ISMS 审计实践指南		10
参考书目		0

前言

ISO（国际标准化组织）和 IEC（国际电工委员会）构成了全球标准化的专门体系。作为 ISO 或 IEC 成员的国家机构，通过各自组织设立的处理特定技术活动领域的技术委员会，参与国际标准的制定。ISO 和 IEC 技术委员会在共同关心的领域进行合作。其他国际组织，包括政府组织和非政府组织，与国际标准化组织和国际电工技术组织保持联系，也参与了这项工作。

用于开发本文件的程序及其旨在进一步维护的程序详见 ISO/IEC 指令，第 1 部分。特别是，应注意不同类型文件所需要的不同批准标准。本文件是根据 ISO/IEC 指令第 2 部分（见 www.iso.org/directives）的编辑规则起草的。

有人提请注意，本文件的某些要素有可能成为专利权的主题。ISO 和 IEC 不应负责识别任何或所有此类专利权。在文件开发过程中确定的任何专利权的细节将在介绍和/或收到的专利声明的 ISO 清单（见 www.iso.org/patents）或收到的专利声明的 IEC 清单（见 <http://patents.iec.ch>）中找到。

本文件中使用的任何商标名称均为为方便用户而提供的信息，不构成背书。

有关标准的自愿性质、ISO 与合格评估相关的具体术语和表达的含义，以及 ISO 在技术性贸易壁垒（TBT）中遵守世界贸易组织（WTO）原则的信息，请参见 www.iso.org/foreword.html。

本文件由 ISO/IEC JTC 1、信息技术、SC 小组委员会 27、信息安全、网络安全和隐私保护联合技术委员会编写。

这第三版取消并取代了第二版（ISO/IEC 27007: 2017），它已经在技术上进行了修订。

与上一版本相比，主要的变化如下：

- 该文件已符合 ISO 19011: 2018 标准；
- 介绍书中的内容已被改写和扩展；
- 在 5A 中，整个文本已被删除；
- 在 5.2.2 中，前一项 d) 已被删除；
- 在 5x3 中，整个文本已被删除；
- 在 552.2 中，前一项 b) 和以下一段已被删除；
- 6.5.22 中第一段已删除，注释重新措辞。

关于本文件的任何反馈或问题都应指向用户的国家标准机构。这些机构的完整名单可以在 www.iso.org/members.html 上找到。

介绍

信息安全管理系统（ISMS）审计可以根据一系列的审计标准，单独或联合进行，包括但不限于：

- ISO/IEC 27001: 2013 中规定的要求；

- 有关利益相关方规定的政策和要求；
- 法定和法规要求；
- 由本组织或其他各方定义的 ISMS 流程和控制；
- 与提供 ISMS 的具体输出有关的管理系统计划（例如，在建立 ISMS 时解决风险和机会的计划、实现信息安全目标的计划、风险处理计划、项目计划）。

本文件为各种规模和类型的组织和不同范围和规模的 ISMS 审计提供指导，包括由大型审计团队进行的，通常是大型组织，以及由单一审计师进行的，无论是大型还是小型组织。本指南应根据 ISMS 审计方案的范围、复杂性和规模酌情进行调整。

本文件集中于 ISMS 内部审计（第一方）和各组织对其外部提供者和其他外部相关方（第二方）进行的 ISMS 审计。本文档也可用于为第三方管理系统认证以外的目的而进行的 ISMS 外部审计。ISO/IEC 27006 提供了针对第三方认证的审核 ISMS 的要求；本文档可提供有用的附加指导。

本文件将与 ISO 19011: 2018 中包含的指南一起使用。

本文件遵循 ISO 19011: 2018 的结构。

ISO 19011: 2018 为审计方案的管理、管理系统的内部或外部审计的实施以及管理系统审计师的能力和评估提供了指导。

附件 A 提供了 ISMS 审计实践的指导，以及 ISO/IEC 27001: 2013 第 4 至 10 条的要求。

信息安全、网络安全和隐私保护——信息安全管理系统审计指南

1 范围

本文件除了在 ISO 19011 中所包含的指导外，还提供了关于管理信息安全管理系统（ISMS）审计方案、进行审计和 ISMS 审计人员的能力的指导。

本文件适用于那些需要了解或对 ISMS 进行内部或外部审计，或管理 ISMS 审计计划的人员。

2 规范性引用文件

文中提及以下文件，其部分或全部内容构成本文件的要求。对于有日期的参考文献，只适用被引用的版本。对于未注明日期的参考文件，适用参考文件的最新版本（包括任何修订）。

ISO 19011: 2018, 审计管理体系指南

ISO/IEC 27000: 2018, 信息技术。安全技术。信息安全管理系统。概述和词汇表

3 术语和定义

就本文件而言，ISO 19011 和 ISO/IEC 27000 中给出的术语和定义均适用。

ISO 和 IEC 在以下地址维护术语数据库以用于标准化：

- ISO 在线浏览平台：可在 <https://www.iso.org/obp> 上获得
- IEC 电子百科：可在 <http://www.electrQpedia.org/> 上获得

4 审计原则

适用 ISO 19011: 2018 第 4 条的审计原则。

5 管理审计计划

5.1 将军

适用 ISO 19011: 2018, 5.1 的指南。

5.2 建立审计计划的目标

5.2.1 适用 ISO 19011: 2018, 5.2 的指南。此外，在中的指导方针也适用。

5.2.2 在确定审计时，具体针对 isms 的考虑事项¹⁾，方案目标可包括：

- a) 已确定的信息安全要求；
- b) ISO/IEC 27001 的要求；
- c) 被审核方的绩效水平，反映在信息安全事件和事件的发生和 ISMS 的有效性上；

注：关于性能监测、测量、分析和评估的进一步信息可在 ISO/IEC 27004 中找到。

d) 对相关各方，即被审计方和审计客户构成的信息安全风险。

针对 isms 的审计方案目标的例子包括：

- 证明符合相关法律和合同要求以及其他要求及其安全影响；
- 获得并保持对被试方风险管理能力的信心；
- 评估应对信息安全风险和机遇的行动的有效性。

5.3 确定和评估审计计划的风险和机会

5.3.1 适用 ISO 19011： 2018, 5. 3 的指南。

5.3.2 根据被听方和其他相关方的要求，确定确保信息安全保密的措施。其他各方的要求可包括相关的法律要求和合同要求。

5.4 建立审计计划

5.4.1 管理审计方案的个人工作人员的角色和职责

适用 ISO 19011： 2018, 5. 4. 1 的指南。此外，还适用于 5. 4. 1. 2 中的指南。

5.4.2 个人管理审计方案的能力

j 适用 ISO 19011： 2018, 5. 4. 2 的指导方针。

i

j5. 4. 3 确定审计方案的范围

i 5. 4. 3. 1 适用 ISO 19011： 2018, 5. 4. 3 的指南。此外，第 543. 2 节中的指导意见也适用。

i

i 5. 43. 2 审计方案的范围可包括以下内容：

I

>a) ISMS 的大小，包括：

)

1) 在组织控制下工作的人员总数，以及与与 ISMS 相关的相关方和承包商的关系；

i

? 2) 表示信息系统的数量；

1) 为本文件的目的，该术语 "审计" 指 ISMS 审计。

3): ISMS 所覆盖的站点数量;

- b) ISMS 的复杂性 (包括过程和活动的数量和临界性), 考虑到在 ISMS 范围内的站点之间的差异;
- c) ISMS 与业务相关的信息安全风险的重要性;
- d) 在规划 ISMS 时所确定的风险和机会的重要性;
- e) 在信息范围内保持信息的机密性、完整性和可用性的重要性;
- f) 待审计的信息系统的复杂性, 包括所部署的信息技术的复杂性;
- g) 类似网站的数量。

在审计方案中应考虑根据信息安全风险的重要性和有关信息范围的业务要求, 确定需要进行更详细审查的优先事项。

注: 关于确定审计时间的进一步信息可在 ISO/IEC 27006 中找到。关于多地点取样的更多信息可在 ISO/IEC 27006 和国际认证论坛的强制性文件 1 中找到 (IAF MD1, 见参考文献[11]) 中找到。ISO/IEC 27006 和 IAF MD 1 中包含的信息仅涉及认证审核。

5.4.4 确定审计计划的资源

5.4.4.1 适用 ISO 19011: 2018, 5.4.4 的指南。此外, 第 544.2 节中的指导意见也适用。

5.4.4.2, 特别是对于适用于被审计方和与审计方案目标相关的所有重大风险, 应分配 ISMS 审计师足够的时间来审查应对信息安全风险和 ISMS 相关风险和机会的行动的有效性。

5.5 实施审计方案

5.5.1 将军

适用 ISO 19011: 2018, 5.5.1 的指南。

5.5.2 定义个别审计的目标、范围和标准

5.5.2.1 适用 ISO 19011: 2018, 5.5.2 的指南。此外, 5x522 中的指南也适用。

5.5.2.2 审计目标可能包括以下内容:

- a) 评估 ISMS 是否能充分识别和解决信息安全要求;
- b) 确定信息安全控制与 ISMS 的要求和程序的符合程度。

审计范围应考虑影响相关方和被审计方即 ISMS 的信息安全风险和相关风险和机会。

以下主题可被视为审计标准, 并作为确定符合性的参考:

- a) 被审核方所采用的信息安全政策、信息安全目标、政策和程序;
- b) 合同要求和与被审核方有关的其他要求;
- c) 被审核方的信息安全风险标准、信息安全风险评估流程和风险处理流程;
- d) 适用性声明、任何特定部门的或其他必要控制的识别、纳入的理由、是否实施以及排除 ISO/IEC 27001: 2013 附件 A 控制的理由;
- e) 对适当处理风险的控制措施的定义;

- f) 对信息安全性能和有效性的监测、测量、分析和评价的方法和标准;
- g) 由客户提供的信息安全要求;
- h) 由供应商或外包商应用的信息安全要求。

5.5.3 选择和确定审核方法

5.5.3.1 适用 ISO 19011: 2018, 5.5.3 的指导方针。此外, 还适用于第 5.5.3.2 节中的指导意见。

5.5.3.2 如果进行联合审计, 应特别注意相关各方之间的信息披露。在审计开始前, 应与所有相关方达成协议。

5.5.4 选择审核团队成员

5.5.4.1 适用 ISO 19011: 2018, 5.5.4 的指南。此外, 5.5.4.2 中的指导意见也适用。

5.5.4.2 整个审计团队的能力应包括以下足够的知识和理解:

i

; a) 足以评估被审核方所用方法的信息安全风险;

I b) 信息安全和信息安全管理, 足以评估 ISMS 的控制确定、规划、实施、维护和有效性。

>

: 5.5.5 将个别审核的责任分配给审核小组组长

适用 ISO 19011: 2018, 5.5.5 的指导方针。

5.5.6 管理审计计划结果

适用于 ISO 19011: 2018, 5.5.6 的指导方针。

5.5.7 管理和维护审计计划记录

适用 ISO 19011: 2018, 5.5.7 的指导方针。

5.6 监测审计方案

适用 ISO 19011: 2018, 5.6 的指南。

5.7 审核和改进审计方案

适用 ISO 19011: 2018, 5.7 的指南。

6 进行审计

6.1 将军

适用 ISO 19011: 2018, 6.1 的指南。

6.2 启动审计

6.2.1 将军

适用 ISO 19011: 2018, 6.2.1 的指南。

6.2.2 与被听方建立联系

6.2.2.1 适用 ISO 19011: 2018, 6.2.2 的指南。此外，以 22 中的指导方针也适用。

6.2.2.2 必要时，应注意确保审计员已获得必要的安全许可，以访问文件化信息或审计活动所需的其他信息（包括但不限于机密或敏感信息）。

6.2.3 确定审计的可行性

6.2.3.1 适用 ISO 19011: 2018, 6.2.3 的指南。此外，QZ32 中的指南也适用。

6.2.3.2 在审计开始前，应询问被审核方是否有任何 ISMS 审核证据无法供审计小组审查，例如，因为该证据包含个人身份信息或其他机密/敏感信息。负责管理审计方案的人应确定，在没有审计证据的情况下，ISMS 是否可以得到充分的审计。如果结论是，在不审查确定的审计证据的情况下无法充分审计 ISMS，负责管理审计方案的人应通知被审计方，在批准适当的访问安排或向被审计方提出了实现审计的替代方法之前，不能进行审计。如果审计继续进行，审计计划应考虑到任何访问限制。

6.3 准备审计活动

6.3.1 对已文档化的信息进行审查

适用 ISO 19011: 2018, 6.3.1 的指南。

6.3.2 审计计划

6.3.2.1 适用 ISO 19011: 2018, 6.3.2 的指南。此外，6322 年中的指导意见也适用。

6.3.2.2 审计团队负责人应意识到，审计团队成员的存在可能会给被审核方带来风险。审计小组的存在可能会影响信息安全，并给被审计方的信息带来额外的风险来源，例如，机密或敏感记录或系统基础设施（例如，意外删除、未经授权的信息披露、信息的意外变更）。

6.3.3 向审核团队分配工作

适用 ISO 19011: 2018, 6.3.3 的指南。

6.3.4 准备可供审核使用的文件化信息

6.3.4.1 适用 ISO 19011: 2018, 6.3.4 的指导方针。此外，第 6.342 条中的指导意见也适用。

6.3.4.2 审核组长应确保所有的审核工作文件都被适当地分类，并按照该分类进行处理。

6.4 开展审计活动

6.4.1 将军

适用 ISO 19011: 2018, 6.4.1 的指南。

6.4.2 分配向导和观察员的角色和职责

适用 ISO 19011: 2018, 6.4.2 的指导方针。

6.4.3 主持开幕会议

适用 ISO 19011：2018, 6.4.3 的指南。

6.4.4 审计过程中的沟通

适用 ISO 19011：2018, 6.4.4 的指南。

6.4.5 审核信息的可用性和访问权限

6.4.5.1 适用 ISO 19011：2018, 6.4.5 的指导方针。此外，第 645.2 节中的指导意见也适用。

i

：6.4.5.Z 如果审计团队在审计过程中因分类或敏感性的原因没有获得任何审计证据，首席审计师应确定这在多大程度上影响了对审计结果和结论的信心，并在审计报告中反思，而不影响不可获得的证据的敏感性。

：6.4.6 在进行审核时，应审查文件信息

)

>6.4.6.1 ISO19011：2018, 6.4.6 的指南，适用。此外，还适用于 6.4.6.Z 中的指南。

)

5 6.4.6.2 ISMS 审核员应核实审核准则所要求的、与审核范围相关的文件化信息是否存在，并符合审核准则的要求。

ISMS 审计员应确认，在审计范围内确定的控制与风险评估和风险处理过程的结果相关，并随后可追溯到信息安全政策和目标。

注：附件 A 为 ISMS 的审计实践提供了指导，包括如何使用相关的文件信息对 ISMS 进行审计。

6.4.7 收集和验证信息

6.4.7.1 适用 ISO 19011: 2018, 6.4.7 的指南。此外, 还适用于 6.4.7.2 中的指南。

6.4.7.Z 在审计期间收集相关信息的可能方法包括:

- a) 审查文件化信息 (包括计算机日志和配置数据);
- b) 参观信息处理设施;
- c) 观察 ISMS 过程及相关控制;
- d) 使用自动审计工具。

注 1: 附件 A 提供了关于如何审计 ISMS 流程的指导。

注 2 ISO/IEC TS 27008 提供了关于如何评估信息安全控制的额外指导。

ISMS 审计小组成员应确保根据审计客户、审计小组和被审核方之间的协议, 适当处理从被审核方处收到的所有信息。

6.4.8 生成审计结果

适用 ISO 19011: 2018, 6.4.8 的指南。

6.4.9 确定审计结论

适用 ISO 19011: 2018, 6.4.9 的指南。

6.4.10 进行闭幕会议

适用 ISO 19011: 2018, 6.4.10 的指南。

6.5 编制和分发审核报告

6.5.1 编制审计报告

适用 ISO 19011: 2018, 6.5.1 的指导方针。

6.5.2 分发审计报告

6.5.2.1 适用于 ISO19011: 2018, 6.5.2 的指南。此外, 第 6522 年决议中的指导意见也适用。

6.5.2.Z 注意事项

注意: 在使用电子手段分发审计报告时, 适当的加密是确保保密要求的一种可能措施。

6.6 完成审计

适用于 ISO19011: 2018, 6.6 的指南。

6.7 进行审计跟踪

适用于 ISO19011: 2018, 6.7 的指南。

7. 审计师的能力和评价

7.1 将军

适用 ISO 19011：2018, 7.1 的指南。

7.2 确定审计员能力

7.2.1 将军

7.2.1.1 适用 ISO 19011：2018, 7.2.1 的指南。此外，L2 上 2 中的指导方针也适用。

7.2.1.2 在决定 ISMS 审计员的适当知识和技能时，应考虑以下事项：

- a) ISMS 的复杂性（例如，ISMS 内的信息系统的临界性，ISMS 的风险评估结果）；
- b) 在 ISMS 范围内执行的业务类型；
- c) 在实施 ISMS 的各个组成部分（如已实施的控制、文档化的信息和/或过程控制、技术平台和所涉及的解决方案等）中所使用的技术的范围和多样性。；
- d) 先前演示的 ISMS 的性能；
- e) 在 ISMS 范围内使用的外包和外部方安排的程度；
- f) 与审计方案相关的标准、法律要求和其他要求。

7.2.2 个人行为

适用 ISO 19011：2018, 7.2.2 的指南。

7.2.3 知识和技能

7.2.3.1 将军

\适用 ISO 19011：2018, 7.2.3.1 的指南。

)

； 7.2.3.2 管理系统审核员的一般知识和技能

： 适用 ISO 19011：2018, 7.2.3.2 的指南。

i

审计人员的纪律和部门的具体能力

)

> 7.2.3.3.1 适用 ISO 19011：2018, 7.2.33 的指导方针。此外，还适用于第 7.2.3.3.2 条中的指导意见。

> 7.2.33.2 ISMS 审计员也应该能够理解相关的业务需求。

)

： 7、Z.3.4 审计组长的一般能力

a

； 适用 ISO 19011：2018, 7.2.3.4 的指导方针。

7.2.3.5 审计多个学科的知识 and 技能

适用于 ISO 19011: 2018, 7.2.3.5 的指导方针。

7.2.4 实现审计能力

7.2.4.1 适用 ISO 19011: 2018, 7.2.4 的指南。此外, 7.2.4.2 中的指导意见也适用。

7.2.4.Z ISMS 审计员应具备信息技术和信息安全方面的知识和技能, 并通过相关认证 (例如通过 ISO/IEC 17024) 进行认证。个人 ISMS 审计员的工作经验也应有助于发展他们在 ISMS 领域的知识和技能。

注: 有关 ISMS 审计人员认证的更多信息请见 ISO/IEC 27006。

7.2.5 实现审计团队领导的能力

适用于 ISO19011: 2018, 7.2.5 的指南。

7.3 建立审计师评估标准

适用 ISO 19011: 2018, 7.3 的指导方针。

7.4 选择合适的审计师评估方法

适用 ISO 19011: 2018, 7.4 的指导方针。

7.5 进行审计师评估

适用 ISO 19011: 2018, 7.5 的指南。

7.6 保持和提高审计师的能力

适用 ISO 19011: 2018, 7.6 的指南。

附件 A
提供信息的
ISMS 审计实践指南

A.1 概述

本附件提供了关于如何审计 ISMS 的通用指导，该组织声称符合 ISO/IEC 27001。由于本指南旨在适用于所有此类 ISMS 审计，无论所涉及的组织的规模或性质如何，因此本指南是通用的。该指南旨在供执行 ISMS 审计的审计人员使用，无论是内部审计还是外部审计。

注：ISO/IEC 27003 根据 ISO/IEC 27001 提供了关于实施和操作 ISMS 的指导。

A.2 概述

A.2.1 审计目标、范围、标准和审计证据

在审计活动期间，应通过适当的抽样方式获得与审计目标、范围和准则有关的信息，包括有关职能、活动和过程之间接口的信息，并应加以核实。只有可核实的信息才应被视为审计证据。应记录导致审计结果的审计证据。

获取信息的方法包括：

- 采访；
- 观察；
- 审查文件，包括记录。

A.2.2 审计 ISMS 的策略

有一些 ISO/IEC 27001: 2013 子条款是密切相关的，在实践中，我在进行审计时最好同时处理。具体示例见表 A.2。

[例如 ISO/IEC 27001: 2013: 6.1.3 和 8.3 和 6.2、5.1、5.2、5.3、7.1、7.4、7.5、9.1、9.3 和 10.2，它呢？用这些相关的和相关的子条款来审计这些子条款是有意义的。

i ISO/IEC 27001: 2013, 7.5，提出了有关文件化信息的要求。如表中所述 A.2, A.4.5，每次审核员检查一项文件化信息时，都有机会确认符合 ISO/IEC 27001: 2013, 7.5 的要求。关于如何检查的指导见表 A.2, A.4.5。文件信息的要求，表中“文件信息”不重复。

A.2.3 审核和文件化信息

：审计活动可以包含有文件化的信息，即：

a) ISO/IEC27001 中文件化信息的要求陈述可作为审计标准；

； b) ISO/IEC 27001: 2013, 7.5.1 要求的文件化信息；

1 c) 由组织确定的为实现有效性所必需的文件化信息： ISO/IEC27001: 2013, 7.5.1c.5.1c)。

可以有 A.2.3 b) 以外的审计证据，审计人员将通过面谈、观察和审查文件，包括记录来获得这些证据。

关于 ISO/IEC 27001 的文件化信息的详细讨论可以在心中找到。

A.3 ISO/IEC27001 要求的指南

A.3.1 基本原理

审计员在要求将文件信息作为符合性的证据时应注意。

有：

- a) 16 对文件化信息的明确要求，包括适用性声明，如表 A.1 所示：
- b) 进一步的要求包括：
 - 1) 有理由期望在上述文件信息中找到一致性的证据；
 - 2) 对文档化的信息没有明确的或隐含的要求。

表 A.1-对 ISO/IEC 27001 中的文件化信息的要求

对有关以下信息的文件化信息的要求	ISO/IEC 27001: 2013 中的子条款
ISMS 的范围	4.3
信息安全策略	5.2
信息安全风险评估流程	6.1.2
信息安全风险处理流程	6.1.3
适用性声明	6.1.3 d)
信息安全目标	6.2
能力的证据	7.2 d)
由组织确定的为 ISMS 有效性所必需的文件化信息	7.5.1 b)
运营规划与控制	8.1
信息安全风险评估的结果	8.2
信息安全风险处理的结果	8.3
监测和测量结果的证据	9.1
审计方案和审计结果的证据	9-2 g)
管理评审结果的证据	9.3
不符合项的性质和随后采取的任何行动的证据	10.1 f)
任何纠正措施的结果的证据	10.1 g)

注：审计工作的定义表明，它是一个文档化的过程，因此，审计人员可以期望达到 ISO/IEC 27001: 2013, 9.2 的要求，从而导致审计工作的过程被文档化。

A.3.2 对文件化信息的隐式要求的示例

作为 A.3.1 b) 1) 的一个例子，考虑 ISO/IEC 27001: 2013, 6.1.2，它要求组织“保留关于信息安全风险评估过程的文档信息”。上述要求[ISO/IEC 27001: 2013, 6.1.2 a) 至 e)]均涉及该风险评估过程。因此，我们有理由期望在有关风险评估过程的所需文件化信息中找到符合这些要求的证据。

A.3.3 对文档化信息没有明确或隐含要求的示例

作为 A.3.1 b) 2) 的一个例子，考虑 ISO/IEC 27001: 2013, 4.1.1。不要求提供关于外部和内部问题的文件化信息。因此，审计员不应要求看到它。然而，该组织未能证明其已确定这些问题将构成与 ISO/IEC 27001: 2013, 4.1.1 的不符合项。然而，组织有责任决定它选择如何证明一致性。可以是最高管理人员可以解释（即有人知道）；可以有会议的记录；它可以在正式配置管理下的文档信息中

得到证明，也可以通过其他方式得到证明。事实上，证据很可能会分散在 ISMS 的记录信息中。例如，ISO/IEC 27001：2013, 4.1.1 的目的是帮助该组织理解其 ISMS 的上下文。这种情况在整个 ISMS 中普遍存在，特别是在确定范围和政策以及执行风险评估和风险处理过程方面，如果组织已经满足了 ISO/IEC 27001：2013, 4.1.1 的要求，其对外部和内部问题的知识可能会用于 ISMS 的其他领域，其使用将是一致的，并可能在这些其他领域的文件信息中有一致性的证据。

A. 4 关于适用性的声明

适用性声明（SoA）是另一个需要注意的领域。SoA 应包含所有必要的控制，即组织由于其风险处理过程[ISO/IEC/27001：2013, 6.1.3c)]，确定为修改信息安全风险以满足它的风险接受标准。所有必要的控制都是组织自身的要求。

必要的控制可以是 ISO/IEC 27001：2013，附件 A，控制，但它们不是强制性的。它们可以从其他标准（例如 ISO/IEC 27017）或其他来源中进行控制，也可以是由组织专门设计的。

在某些情况下，组织使用 ISO/IEC 27001：2013 附录 a 的控制，控制并排除了原 ISO/IEC 27001：2013 附件 a 的控制，排除的理由是它已被组织的控制变化所取代。或者，该变化可以包括 ISO/IEC 27001：2013，附件 A，控制，因此，它将被排除。

审核员应寻找符合组织必要控制的规范，而不是 ISO/IEC 27001：2013，附录 a 中给出的规范。如果组织的规范 j 要求有文件化的程序，那么这构成了组织符合\ ISO/IEC 27001：2013, 7.5.1 b)的一部分。如果没有，审计人员就不应该要求看到它。审计员应该注意到，是吗？但是，要求[ISO/IEC 27001：2013, 8.1)]，组织应“保持文件化；必要的信息，以确保流程已按照计划的方式进行”。由于 ISO/IEC 27001：2013, 8.1 指 ISO/IEC 27001：2013, 6.1，组织的风险；治疗计划及其必要的控制，在\文件信息的要求范围内。

在审计控制的选择时，最好根据 ISO/IEC27001：2013, 6.1.3e)中所述的信息安全风险处理计划|进行审计，而不是根据适用性声明中列出的个别必要的控制。这是因为信息安全风险处理计划(s)可能指定必要控制之间的交互，如果只使用适用性声明，这可能会忽略这个考虑。

A. 5 其他记录的信息

；ISO/IEC 27001 标准的重点是研究结果。对文件化信息的 16 个明确要求；（见表 A.1）。只有三个相关规范（信息安全风险评估流程、j 信息安全风险处理流程和审计方案）。然而，这并不妨碍：一个组织拥有有文档记录的过程。这些支持文件属于 ISO/IEC 27001：2013, 7.5.1 b)的范围（由组织确定为其 ISMS 有效性所必需的文件化信息）。因此，它成为一个组织的要求，因此，应在审计的范围内。

A. 6 注释

所需的信息可以是网页的一部分，也可以作为数据库查询的结果呈现给读者。此外，除适用性声明外，ISO/IEC 27001 不提供文件的名称。因此，有关信息安全策略的文档化信息可能不在名为“信息安全策略”的文档或网页中。组织有权将信息安全策略称为其他方法。负责和授权确保信息安全管理系统符合 ISO/IEC 27001：2013, 5.3 a)要求的人，应知道 ISO/IEC 27001 规定的文件化信息要求与其文件化信息之间的关系。

A. 7 关于 ISMS 的审计指南

表 A.2 列出了以下信息：

- 第一行：对应的 ISO/IEC 27001：2013 条款的编号和名称；
- 第二行：相关子句（关于如何使用该行的信息，见 A.2.2）；
- 第三行：ISO/IEC 27001：2013 条款的 ISO/IEC 27000：2018 的相关定义；
- 第四行：****审计证据****有关相应的 ISO/IEC 27001：2013 子条款的可能信息来源；
- 第五行：“审计实践指南”的审计指南（见 A3）；
- 第六行：“支持文件”¹参考进一步的文件，这可能有助于审计相应的 ISO/IEC 27001：2013 子条款。

表 A. 2-ISO/IEC27001 的审核指南

A.1 组织背景 (ISO/IEC 27001：2013，第 4 条)
A.1.1 了解组织及其上下文 (ISO/IEC27001：2013, 4.1)

相关 ISO/IEC 27001 subclauses	ISO/IEC 27001:2013, 6.1, 9.3
相关 ISO/IEC 27000 定义	外部上下文、信息安全、内部上下文、管理系统，或- ganization
审计证据	审计证据可通过文件化信息或其他信息获得： a) 可以积极或消极地影响 ISMS 的重要问题； b) 公家 c) 本组织的目的； d) ISMS 的预期结果。 这些重要问题的可能来源可以包括：

表 A.2 (续)

	a) 与气候、污染、资源可用性和生物多样性相关的环境特征或条件，以及这些条件对该组织实现其目标的能力可能产生的影响； b) 外部文化、社会、政治、法律、监管、金融、技术、经济、自然和竞争环境，无论是国际、国家、区域还是地方； c) 组织的特征或条件，如组织治理、信息流和决策过程； — 组织性的政策、目标和实现它们的战略； — 组织的文化； — 本组织所采用的标准、指导方针和模式； — 本组织的产品和服务的生命周期； — 在信息安全管理基础上的信息系统、流程、科学和技术； d) 审计和风险评估的趋势。
审计实践指南	审计员应确认该组织： a) 对可能积极或消极地影响 ISMS 的重要问题有一个高水平的（例如战略上的）理解； b) 了解与其目的相关的外部 and 内部问题，并影响其实现其 ISMS 的预期结果的能力。 注 1 ISO/IEC27001:2013, 4.3 中的要求是“考虑 ISO/IEC 27001:2013, 4.1 中提到的外部和内部问题”⁴。组织可以考虑输出中不一定出现的东西。 审计员还应确认，预期的结果包括通过应用风险管理过程来保持保密性、信息的完整性和可用性，以及风险得到了充分的管理。 审计员还应核实这些问题是否包括组织的重要主题、需要辩论和讨论的问题或不断变化的情况，并核实所获得的知识是否用于指导组织计划、实施和操作管理系统的努力。
支持文件	ISO 31000: 2018, 5.3 ISO/IEC 27003:2017, 4.1
A.1.2 了解相关各方的需求和期望 (ISO/IEC27001: 2013、4.2)	
相关 ISO/IEC 27001 subclauses	ISO/IEC 27001:2013, 4.1, 43
相关 ISO/IEC 27000 定义	利害关系方
审计证据	审计证据可通过文件信息或其他信息获取以下信息获取： a) 利害关系人； b) 适用于 ISMS 和 ISO/IEC 27001 的相关利益相关方的需求和期望。 注 2：潜在的利益相关方可包括： a) 法律和监管机构（地方、地区、州/省、国家或国际）；

表 A.2 (续)

	b) 母公司； c) 客户 d) 贸易和专业协会； e) 社区团体 f) 非政府组织 g) 年代叩钳子； h) 邻居 i) 本组织的成员和其他代表本组织工作的人员； j) 信息安全专家。 注 3：利益相关方的要求可包括： a) 法律 b) 许可证、许可证或其他形式的授权； c) 由监管机构发出的命令； d) 法院、行政法庭的判决； e) 条约、公约和议定书； f) 相关的行业规范和标准； g) 已经签订的合同； h) 与社区团体或非政府组织签订的协议； i) 与公共当局和客户签订的协议； j) 组织要求； k) 自愿性的原则或行为守则； l) 自愿贴上标签或履行环境承诺； m) 与组织的合同安排产生的义务； n) 信息和沟通交流。 注 4 利益相关方可以有不同的利益，这些利益可以完全一致、部分一致或反对组织的业务目标。一个利益与组织目标相反的例子就是黑客。黑客要求该组织具有薄弱的安全性。组织应考虑到这个利益相关方的要求，要有完全相反的要求，即强大的安全。 审计员应知道，ISMS 考虑了所有内部和外部风险源。因此，组织对反对组织的相关方及其需求的理解是高度相关的。
审计实践指南	审计员应确认该组织对适用于 ISMS 和 ISO/IEC 27001 的相关利益相关方的需求和期望有高水平的（如战略）理解。 审计师应该验证组织已经确定了相关方要求，它决定自愿采用或签订协议或合同，以及他们的需求和期望是强制性的，因为他们已经被纳入法律、法规、许可和许可证由政府或法院的行动。值得注意的是，并非所有利益相关方的要求都是组织的要求，有些要求并不适用于组织或与 ISMS 相关。某些相关方的需求（例如黑客的需求）将与 ISMS 的目的相反，该组织将通过适当的信息安全控制确保这些需求和期望没有得到满足。 审计员还可以确认，有相关方认为自己受到 ISMS 的影响，如果有，他们会通知组织。 审计员还可以验证该组织是否利用所获得的知识来指导其计划、实施和操作 ISMS 的努力。

表 A.2 (续)

支持文件	ISO 31000: 2018, 5.3 ISO/IEC 27003:2017, 4.2
A.1.3 确定信息安全管理系统的范围 (ISO/IEC 27001: 2013, 4.3)	
相关 ISO/IEC 27001 子条款	ISO/IEC 27001:2013, 4.1, 4.2
相关的 ISO/IEC 27000 的定义	外包
审计证据	审计证据可以通过以下文件化信息或其他信息获得： — 组织管理体系的范围（由 ISO/IEC27001: 2013, 4.3 所定义）； — 一个组织的认证的范围，如果适用； — 适用性声明。 注 5：一个组织的认证范围不一定与其 ISMS 的认证范围相同。一般来说，认证的范围将仅限于 ISMS 组织。
审计实践指南	审计员应确认组织建立了应用 ISMS 的物理、信息、法律和组织边界，并选择在整个组织内或作为组织内的特定单位或特定职能)实施 ISO/IEC 27001。 审核员应确认在确定 ISMS 范围时，已充分考虑了组织对其背景的理解（ISO/IEC27001: 2013, 4.1）、相关利益相关方的要求（ISO/IEC27001: 2013, 4.2）以及组织与其他组织执行的活动之间的接口和相关关系[ISO/IEC27001: 2013, 4.3c)]。 审计员应进一步确认，本组织的信息安全风险评估和风险处理适当地反映了其活动，并延伸到 ISMS 范围内适用于审计范围的活动范围。审计员应核实在每个范围内至少有一份适用性声明，以及在风险管理过程中确定的所有控制都包含在适用性声明)中。这些控制是 ISO/IEC 27001: 2013, 6.1.3 b)中提到的必要控制，并不一定是 ISO/IEC 27001: 2013, 附录 A 控制。它们可能包括由组织设计或从任何来源确定的特定部门的控制和控制。 审计员还应确认，与不完全在 ISMS 范围内的服务或活动的接口已在待审计的 ISMS 范围内得到处理，并包括在组织的信息安全风险评估中。这种情况的一个例子是与其他组织共享设施（例如 IT 系统、数据库和电信系统或外包业务功能）。 应验证范围的文件是否根据文件信息的要求创建和控制（ISO/IEC 27001: 2013, 7.5）。
支持文件	ISO 31000: 2018, 5.3 ISO/IEC 27003:2017, 4.3 ISO/IEC 27006: 2015, 8.2, 9.1.3.5 (IS 9.1.3 认证范围) ISO/IEC 17021-1:2015, 8.2.2
A.1.4 信息安全管理体系 (ISO/IEC27001: 2013, 4.4)	
ISO/ IEC 27001 标准中的相关条款	ISO/IEC 27001:2013, 6.1.1, 6.1.2, 6.1.3, 8.1, 8.2, 8.3

相关 ISO/IEC 27000 定义	持续改进，信息安全、管理体系
------------------------	----------------

表 A.2 (续)

审计证据	审计证据可以通过 ISO/IEC 27001 中要求建立的过程的文件化信息或其他信息来获得，其中包括： a) 管理体系的流程（ISO/IEC27001：2013，4.4）； b) 运营规划和控制流程，包括外包流程（ISO/IEC27001：2013、8.1）； c) 在规划 ISMS 时处理风险和机遇的流程，包括信息安全风险评估流程（ISO/IEC27001：2013、6.1.2 和/或 8.1.2）和信息安全风险处理流程（ISO/IEC27001：2013、6.1.3 和/或 8.1.3）； d) 实现信息安全目标的流程。
审计实践指南	审计员应确认该组织创建了“必要但充分”的流程和控制集，共同形成了一个符合 ISO/IEC 27001 的有效管理体系，并建立了这些相互关联或相互作用的元素集的 ISMS。 审计员还应确认，该组织以其现有能力保留权力、责任和自主权，以决定如何满足 ISMS 要求，包括将 ISMS 要求纳入其业务的细节水平和程度。
支持文件	ISO 31000：2018，5.3 ISO/IEC 27003：2017，4.4
A.2 领导能力（ISO/IEC 27001：2013，第 5 条）	
A.2.1 领导能力和承诺（ISO/IEC 27001：2013、5.1）	
ISO/ IEC 27001 标准中的相关条款	ISO/IEC 27001：2013，4.1，4.2，4.4，5.2，5.3，6.1.1，6.2，7.1，7.4，8.1，9.3，10.2
相关 ISO/IEC 27000 定义	信息安全，最高管理人员
审计证据	审计证据可通过文件化信息或其他信息获得： a) 信息安全政策（ISO/IEC27001：2013，5.1a））； b) 信息安全目标[ISO/IEC27001：2013，5.1a）]； c) 组织的过程； d) 管理评审的结果[ISO/IEC27001：2013，5.1 c)，e) 和 g)]； e) 资源需求评估； f) 沟通有效的信息安全管理的重要性和符合信息安全管理体系要求的重要性。 证据也可以通过与高层管理人员的面谈来获得。管理评审的结果还可以提供除 ISO/ IEC 27001：2013、5.1 c)、e) 和 g) 以外的其他条款之外的审计证据。
审计实践指南	审计员应确认组织最高管理层的可见支持、参与和承诺，这对成功实施 ISO/ IEC 27001 的实施非常重要。 审计人员还应核实： a) 确定了最高管理人员委派的任务； b) 最高管理层仍然负责圆满完成分配给组织的活动； c) 最高管理层确保建立信息安全政策和目标，并与整个组织的战略方向保持一致； d) 最高管理层传达了有效的信息安全管理符合 ISMS 要求的重要性；

表 A.2 (续)

	e) 最高管理人员通过支持所有信息安全管理流程的实施,特别是通过请求和审查有关 ISMS 状态和有效性的报告,确保 ISMS 达到其预期结果[见 ISO/IEC 27001: 2013, 5.3 b)]; f) 最高管理层指导和支持组织中直接参与信息安全和 ISMS 的人员; g) 最高管理层确保将 ISMS 需求集成到组织的流程中; h) 最高管理层确保了拥有有效的 ISMS 的资源可用性; i) 最高管理人员在管理评审期间评估资源需求,并为持续改进和监测计划活动的有效性设定目标; j) 最高管理人员创造了一种文化和环境,鼓励人们积极努力实施 ISMS 的要求,并寻求实现信息安全目标。
支持文件	ISO 31000: 2018, 4.2 ISO/IEC 27003:2017, 5.1
A.2.2 政策 (ISO/IEC27001: 2013, 5.2)	
ISO/ IEC 27001 标准中的相关条款	ISO/IEC 27001:2013, 6.2, 7.4
相关 ISO/IEC 27000 定义	信息安全、政策
审计证据	审计证据可以通过文件化信息或其他形式获得: a) 信息安全政策 (ISO/IEC27001: 2013, 5.1); b) 信息安全目标[ISO/IEC 27001: 2013, 5.2 b) 和 ISO/IEC 27001:2013, 6.2].
审计实践指南	审计员应确认: a) 信息安全政策规定了 ISO/IEC 27001 所要求的高级组织承诺,并考虑到组织的目的; b) 信息安全策略可用于构建或构建组织为自己设定的信息安全目标,或将信息安全策略明确声明为信息安全策略的一部分; c) 信息安全政策的文件信息是根据文件信息的要求创建和控制 (ISO/IEC 27001: 2013, 7.5); d) 根据通信条款 (ISO/IEC 27001: 2013, 7.4) 的要求,信息安全政策进行内部沟通; e) 该信息安全政策也可适当地提供给其他利益相关方。 由于信息安全政策包含了满足适用要求的承诺,特别是相关法律法规,只要 ISMS 导致及时发现和纠正导致不符合要求实例的系统缺陷,就不应被视为不符合要求。
支持文件	ISO 31000: 2018, 4.3.2 ISO/IEC 27003:2017, 5.2

表 A.2 (续)

A.2.3 组织机构的角色、职责和权限 (ISO/IEC 27001: 2013, 5.3)	
相关的 ISO/ I EC 27001 条款	ISO/IEC 27001:2013, 7.4, 9.2, 9.3
相关 ISO/IEC 27000 定义	信息安全、组织结构、最高管理人员
审计证据	考虑到 ISO/IEC 27001: 2013, 7.5.1 b), 审计证据可通过文件化信息或其他信息获得: a) 组织角色; b) 在其控制下工作、可能对组织信息安全绩效有影响的人员的工作描述; c) 内部审计方案的实施情况和审计结果; d) ISMS 是指该组织的范围和结构。 此外, 还可以通过文件化的信息或关于管理审查结果的其他信息获得进一步的审计证据。
审计实践指南	审核员应通过审查文件化信息和/或面谈来确认: a) 实施 ISMS 要求的职责和权力被分配给组织内的相关角色; b) 最高管理层对这些职责负责, 并且当局被分配并沟通给执行这些角色的各自人员; c) 根据沟通条款 (ISO/IEC27001: 2010.4) 的要求, 沟通职责和权限; d) 证明符合 ISO/IEC 27001 的要求应按照内部审核的要求进行 (ISO/IEC 27001: 2013, 9.2); e) 绩效报告按照管理评审的要求进行 (ISO/IEC 27001: 2013, 9.3)。 审计员应核实负责的个人是否有足够的机会接触最高管理层, 以使管理层随时了解 ISMS 的状态和表现。 注 6: 确保管理系统符合 ISO/IEC 27001 的要求的作用可以分配给一个人, 由几个人共享或分配给一个团队。
支持文件	ISO 31000: 2018, 4.3.3 ISO/IEC 27003:2017, 5.3
A.3 规划 (ISO/IEC 27001: 2013, 第 6 条)	
A.3.1 应对风险和机遇的措施 (ISO/IEC 27001: 2013, 6.1)	
A.3.1.1 通用版 (ISO/IEC 27001: 2013, 6.1.1)	
相关 ISO/ IEC 27001 条款	ISO/IEC 27001:2013, 4.1, 4.2, 8.1, 9, 10.2
相关 ISO/IEC 27000 定义	信息安全、风险、风险管理
审计证据	审计证据可通过文件化信息或其他信息获得: a) 规划 ISMS [ISO/IEC 27001: 2013, 6.1.1, 7.5.1 b) 和 8.1]; b) 信息安全风险评估流程 (ISO/IEC27001: 2013, 6.1.2); c) 信息安全风险评估的结果 (ISO/IEC27001: 2013, 8.2); d) 信息安全风险处理流程 (ISO/IEC 27001: 2013, 6.1.3); e) 信息安全风险处理的结果 (ISO/IEC27001: 2013, 8.3);

表A.2 (续)

	f) 监测和测量的结果 (ISO/IEC27001: 2013, 9.1) ; g) 内部审计计划(s)和内部审计结果 (ISO/IEC27001: 2013, 9.2) ; h) 管理评审的结果 (ISO/IEC27001: 2013, 9.3) ; i) 组织的背景 (ISO/IEC27001: 2013、4) ; j) 信息安全目标 (ISO/IEC 27001: 2013, 6.2) 。
审计实践指南	审核员应确认该计划: a) 正在在适合建立 ISMS 的水平上执行; b) 包括考虑 (ISO/IEC 27001: 2013, 4.1) 中确定的与组织背景相关的问题, 以及 (ISO/IEC27001: 202013, 4.3)中确定的组织的适用要求, 以解决与 ISO/IEC 27001: 2013, 6.1.1 相关的任何负面或积极后果) ; c) 已预期潜在的情况和后果, 因此在不良影响发生之前加以预防; d) 解决由组织确定的预期结果[ISO/IEC 27001: 2013, 6.1.1 a)], 其中包括通过应用风险管理流程来保护信息的机密性、完整性和可用性; e) 包括确定如何通过客观设定 (ISO/IEC27001: ISO2713、6.2) 、操作控制 (ISO/IEC 27001: 2013、8.1) 或 ISO/IEC 27001 的其他具体条款, 如资源规定 (ISO/IEC 27001: 2013、7.1) 、能力 (ISO/IEC 27001: 2013、7.2) 、信息安全风险评估 (ISO/IEC 27001: 2013、8.2) 、信息安全风险处理 (ISO/IEC 27001: 2013、8.3) ; f) 包括确定评估所采取行动的有效性的机制, 并可包括监测、测量技术 (ISO/IEC27001: 2013、9.1) 、内部审计 (ISO/IEC27001: 2013、9.2) 或管理评审 (ISO/IEC27001: 2013、9.3) 。
支持文件	ISO31000: 2018, 5.3 至 5.7 ISO/IEC 27003:2017, 6.1.1
A.3.1.2 信息安全风险评估 (ISO/IEC27001: 2013, 6.1.2)	
相关 ISO/IEC 27001 subclauses	ISO/IEC 27001:2013, 8.2
相关 ISO/IEC 27000 定义	可用性、机密性、信息安全、完整性、风险接受度、风险分析、风险评估、风险标准、风险识别
审计证据	审计证据可通过文件化信息或其他信息获得: a) 规划 ISMS [ISO/IEC 27001: 2013, 6.1.1, 7.5.1 b) 和 8.1)]; b) 信息安全风险评估流程 (ISO/IEC 27001: 2013, 6.1.2) 和信息安全风险评估结果 (ISO/IEC 27001: 2013, 8.2) 。
审计实践指南	审计员应确认是否应进行信息安全风险评估: a) 识别与 ISMS 相关联的安全信息风险; b) 包括风险识别、风险分析和风险评估过程。
	风险标准 ISO/IEC 27001: 2013, 6.1.2 a)
	审计员应确认该组织已经建立并维护了风险验收标准和执行信息安全风险评估的标准。

尽管组织可以自由考虑其认为与建立风险标准相关的任何因素, 包括风险接受标准和执行信息安全风险评估的标准, 但审计人员应评估组织建立其风险标准, 包括风险接受标准和基于知情决策执行信息安全风险评估的标准。

表A.2 (续)

有理由期望组织的风险标准包含在有关风险评估过程的文档化信息中。如果没有, 该组织应该能够向审计员

解释他们是什么。至少，它们应该包括组织*风险接受标准和执行风险评估的标准。

注 7 ISO/IEC 27001: 2013, 8.2 要求组织在计划的时间间隔内，或在提出或发生重大变更时进行信息安全风险评估。风险评估可以对所有 ISMS 或其部分内容进行（最后一种情况可以显示，当重大变化对 ISMS 的部分内容产生影响时，然后需要进行新的部分风险评估）。

结果的一致性、有效性和可比性[ISO/IEC 27001: 2013, 6.1.2 b)]

审计员应确认信息安全风险评估过程中的风险评估结果是一致、有效和可比性的。此确认可通过以下方式执行：

— 询问组织为什么其自己的风险评估结果是一致、有效和可比性的；

— 对有关信息安全风险评估结果的记录信息进行抽样。

为了评估一致性和有效性，审计师可以验证是否：

— 在类似情况下的类似风险也进行了类似的评估；

— 不同评估的风险有造成这种差异的理由；

— 总体评估结果是明确可以理解的。

为了评估可比性，审计人员可以验证：

— 在以前的风险评估中如何评估相同的风险，如果它发生了变化是否可以理解；

— 如果一个风险高于或低于其他风险，这是明确可以理解的。

风险识别[ISO/IEC 27001: 2013, 6.1.2 c)]

审计员应确认，该组织已确定了与 ISMS 范围内信息的机密性、完整性和可用性的丧失相关的信息安全风险。

注 8 ISO/IEC 27001: 2013 不要求通过识别资产、威胁和漏洞来识别风险。其他的风险识别方法也是可以接受的，例如通过考虑事件和后果来识别风险。

可以合理地预期在其有关风险评估过程的文件化信息中找到对该组织的风险识别过程的描述（见下文）。本组织在制定风险识别方法时可以考虑（但不需要）的因素可包括：

a) 如何发现、识别和描述风险；

b) 需要考虑的风险来源。

组织可以考虑（但不需要）的其他因素包括：

a) 风险如何创造、增强、预防、降低、加速或延迟组织的信息安全目标的实现；与不追求机会相关的风险；

b) 风险，无论其来源是否在组织的控制下，即使风险来源或原因可能不明显；

c) 检查特定后果的连锁效应，包括级联效应和累积效应；

d) 考虑到广泛的后果，即使风险来源或原因可能不明显；

表 A.2 (续)

e) 考虑可能的原因和情景，以显示可能发生的后果；

f) 考虑到所有重要的原因和后果；

g) 如何生成一个全面的风险列表。

注 9: 如果发现无意中遗漏了大量必要的控制，这可能表明风险识别过程较弱。

应在抽样时确认，ISMS 范围内的所有重要信息都包含在风险评估中。

审计员应核实有关风险评估结果的文件化信息中是否存在与 ISMS 范围内信息的机密性、完整性和可用性丧失相关的风险。组织的信息安全目标可以帮助审计人员识别信息安全风险。

审计员还应确认：

a) 对于每个风险，已经确定了风险所有者；

b) 每个风险所有者都有权管理其确定的风险。

风险分析[ISO/IEC 27001: 2013, 6.1.2 d)]

审计员应确认：

a) 组织理解已识别风险的性质，并确定风险的水平，作为信息安全风险评估过程中的风险分析；

b) 风险分析为风险评估和关于需要如何处理风险以及最适当的风险治疗、策略和方法的决定提供了一个输入。

审计员还应确认，该组织已经评估了与其根据 ISO/IEC 27001: 2013, 6.1.2 c) 确定的风险相关的潜在后果和可能性，从而确定了风险水平。

可以在有关风险评估过程的文档信息中找到组织风险分析方法的描述，结果将在有关风险评估结果的文档信息中（见下文）。审计员应参考本组织的风险管理政策、策略、方法。

风险分析可以是：

- a) 根据风险、分析的目的以及可用的信息、数据和资源，进行不同程度的细节分析；
- b) 定性的、半定量的或定量的，或两者的组合，取决于情况。

风险评估[ISO/IEC 27001: 2013, 6.1.2]]

审计员应确认该组织已将其风险分析的结果与信息安全风险接受标准进行了比较，以确定已识别风险的可接受性。

审计员还应确认，风险评估的结果显示，风险接受标准已被适当应用，以及已确定和分析的风险已被优先进行治疗的证据。

在更多细节中，审计员应审查该风险评估：

- a) 根据风险分析的结果，协助就风险如何需要治疗和实施治疗的优先事项作出决定；
- b) 包括将分析过程中发现的风险水平与考虑上下文时建立的信息安全风险标准进行比较。

审计员还应评估下列决定：

- a) 考虑到了更广泛的风险背景；

	表 A.2 (续) b) 考虑相关相关方的要求，包括法律、法规和其他要求。 文件化信息 (ISO/IEC27001: 2013, 6.1.2 和 8.2) 审计员应确认是否存在有关风险评估过程的文件化信息。 我们有理由认为，有关信息安全风险评估过程的文件化信息将包括： a) 风险标准的定义，包括风险接受标准和执行信息安全风险评估的标准； b) 研究结果的一致性、有效性和可比性的基本原理； c) 风险识别过程的描述（包括风险所有者的识别）； d) 描述信息安全风险的分析过程（包括评估潜在后果、现实可能性和最终风险水平）； e) 描述将结果与风险标准进行比较的过程，以及风险治疗中风险的优先级。 注 10 上述项目都符合 ISO/IEC 27001 的要求，这就是为什么在有关风险评估过程的文件信息中找到它们的信息是合理的。
支持文件	ISO 31000: 2018, 5.3、5.4、S.7 ISO/IEC 27003:2017, 6.1.2, 8.2

A.3.1.3 信息安全风险处理 (ISO/IEC 27001: 2013, 6.1.3)

ISO/ IEC 27001 标准中的相关条款	ISO/IEC 27001: 2013, 8.3, 附录 A
相关 ISO/IEC 27000 定义	控制、控制目标、文件化信息、信息安全、残余风险、风险评估、风险标准、风险所有者、风险处理
审计证据	审计证据可通过文件化信息或其他信息获得： a) 计划 ISMS； b) 信息安全风险处理流程； c) 信息安全风险处理的结果； d) 适用性声明。
审计实践指南	信息安全风险处理 (ISO/IEC 27001: 2013, 6.1.3) 审核员应确认该组织将信息安全风险修改为一个信息安全风险处理过程。 审计员还应审查信息安全风险处理是否包括： a) 选择一个或多个选项来修改信息安全风险，并实施这些提供或修改控制的选项； b) 一个评估该治疗方法有效性的周期性过程。 选择适当的信息安全风险处理方案 [ISO/IEC 27001: 2013, 6.1.3 a)] 审计员应确认有关风险处理过程的文件信息包含组织选择适当信息安全风险处理方案的方法的描述。 审计员还应确认此描述与组织实际执行的操作相符。 请注意，ISO/IEC 27000: 2018, 3.72, 注 1 列举了 7 种风险治疗方案，在 ISO/IEC 27001: 2013, 6.1.3 中有一个引用 ISO 31000 的注释。

表 A.2 (续)

审计员应验证风险标准和风险治疗计划之间的一致性。该组织应该能够解释它关于风险治疗方案的决定，即使这些决

定没有被记录下来。

审计员应审查该组织所选择的危险处理方案。审计员还应审查所选的危险治疗方案的适当性。

审计师应核实最近的变更（例如，新的 IT 系统或业务流程）是否已被适当地纳入风险评估和危险处理决策中。

确定所有必要的控制措施[ISO/IEC 27001: 2013, 6.1.3 b)]

审计员应确认，有关危险处理过程的文件化信息包含了该组织用于确定必要的信息安全控制的方法的描述。审计员还应确认，这一描述与该组织的实际工作相对应。

[ISO/IEC 27001: 2013, 6.1.3 d)]要求适用性声明中包含必要的控制。必要的控制不需要是 ISO/ IEC 27001: 2013, 附录 A 控制。它们可能是特定部门的控制（在行业特定标准中定义，如 ISO/IEC 27011、ISO/IEC 27017）。它们也可以是“自定义控制”*，因为组织可以设计他们自己的或从任何来源识别[见 ISO/IEC 27001: 2013, 6.1.3 b)]。

被确定为实施危险治疗方案的 AH 控制应包括在适用性声明中。此外，任何自定义控件都应该明确地定义为在需求和实现中。

比较与 AnUfiXA [ISO/IEC 27001: 2013, 6.1.3 c)]

通过审查以下所述的适用性声明，可以证明其是否符合此要求。

生成适用性声明[ISO/IEC 27001: 2013, 6.1.3)]

审计员应核实适用性声明是否包括：

- a) 通过应用 ISO/IEC 27001: 2013, 6.1.3 b) 和 c) 的过程中确定的必要控制措施；
- b) 纳入它们的理由（例如参考使用的危险治疗方案）；
- c) 是否实施了必要的控制；
- d) 例如，对所有被排除的附件 a 控制的理由。：
 - 1) 该控制适用于该组织没有参与的活动；
 - 2) 组织使用自定义控件，避免了对附件 a 控件的需要；
 - 3) 组织使用与附件 A 控件具有相同用途的自定义控件（进一步信息见 ISO/IEC27003）；
- e) 相关部门特定控制，将被指定为必要的控制，或以与排除的附件 A 控制相同的方式处理。

因此，审计员应确认实现所选危险治疗方案所需的控制与适用性声明之间的一致性。

制定危险处理计划[ISO/IEC 27001: 2013, 6.1.3)]

审计员应确认有关危险处理过程的文件信息包含组织制定危险处理计划的方法的描述。

审核员还应确认危险处理计划已从 ISO/IEC 27001: 2013, 6.1.3 的输出 a) 到 c) 制定。

审计员应进一步确认，在治疗计划中提供的信息包括或链接到：

表 A.2 (续)

	a) 该计划所涉及的风险； b) 必要的控制； c) 如何期望通过必要的控制来修改风险，以满足风险接受标准； d) 风险所有者； 注 11 风险所有人负责批准风险处理计划并接受剩余风险。 e) 选定的风险治疗方案(s)； f) 必要的控制措施的实施情况； g) 选择治疗方案的原因，包括预期将获得的好处； h) 建议的行动，包括负责的个人、时间表和里程碑； i) 资源需求，包括意外事件； j) 绩效衡量标准和约束条件； k) 报告和监控。 审计员应审查风险处理计划是否考虑到组织的客观设定和管理流程，并与相关的利益相关方进行讨论。
	获得风险所有者批准 [ISO/IEC 27001: 2013, 6.1.3 f)]
	审计员应确认该组织 a) 确定适当的风险所有者； b) 记录剩余风险； c) 获得风险所有者*对信息安全风险处理计划的批准和剩余风险的验收。
	记录的信息
	审计员应确认是否存在有关风险处理过程的文件化信息。 我们有理由认为，有关信息安全风险处理过程的文档化信息将包含以下描述： a) 选择适当的信息安全风险处理方案的方法； b) 确定必要的控制措施的方法； c) 如何使用 ISO/IEC 27001: 2013, 附录 A 来确定必要的控制没有被无意中忽视； d) SoA 是如何产生的； e) 如何制定风险处理计划； f) 如何获得风险所有者*的批准。 注 12 对组织的风险治疗计划的内容或格式没有特别的要求。
支持文件	ISO 31000: 2018、5.5、5.7 ISO/IEC 27003:2017, 6.1.3, 8.3 ISO/IEC 27006
A.3.2 信息安全目标和实现这些目标的计划 (ISO/IEC 27001: 2013, 6.2)	
相关的 ISO/IEC 27001 条款	ISO/IEC 27001:2013, 5.1, 5.2, 7.1, 7.3, 7.4, 7.5, 9.1, 9.3, 10.2
相关 ISO/IEC 27000 定义	信息安全、目标

表 A.2 (续)

审计证据	审计证据可以通过关于实现信息安全目标和计划的文件化信息或其他信息来获得。
审计实践指南	值得注意的是，信息安全目标和计划实现这些目标（ISO/IEC 27001: 2013, 6.2）与领导和承诺（ISO/IEC 27001: 2013, 5.1）和政策（ISO/IEC 27001: 2013, 5.2）存在联系。 审计员应确认： a) 在组织的相关职能和级别上建立了信息安全目标； b) 信息安全目标的指定方式允许确定其实现情况； c) 如果适用，目标是可测量的（可能有些情况下，测量信息安全目标可能不可行）； d) 根据监测、测量、分析和评估的要求（ISO/IEC 27001: 2013, 9.1），定期验证实现信息安全目标的状态和进度，并适当更新，符合持续改进的要求（ISO/IEC 27001: 2013, 10.2）； e) 信息安全目标和实现它们的计划按照通信的要求进行沟通（ISO/IEC 27001: 2013, 7.4）； f) 目标的文档信息是根据文档信息的要求创建和控制（ISO/IEC 27001: 2013, 7.5）。 审计人员还应核实： a) 确定了实现信息安全目标（即“什么”）和相关的时间框架（即“何时”）所需的行动； b) 职责分配（即“谁”）根据组织角色、职责和权限的要求确定（ISO/IEC27001: 2013, 5.3）； c) 在实现它们的目标和计划中，都考虑了适用的信息安全要求，以及风险评估和风险处理的结果； d) 例如，实现目标对预算、专门技能、技术或基础设施的任何需要都是根据资源要求确定和提供的（ISO/IEC 27001: 2013, 7.1）； e) 根据监测、测量、分析和评估的要求（ISO/IEC 27001: 2013, 9.1）确定，并根据管理评审（ISO/IEC/27001: 2013, 9.3）的要求进行报告。
支持文件	ISO/IEC 27003:2017, 6.2
A.4 支持(ISO/IEC 27001: 2013, 第7条)	
A.4.1 参考资料 (ISO/IEC 27001: 2013, 7.1)	
相关 ISO/IEC 27001 条款	ISO/IEC 27001:2013, 5.1, 6.2, 7.2
相关 ISO/IEC 27000 定义	持续改进，管理体系
审计证据	审计证据可以通过文件信息或组织需要的资源的其他信息获得： a) 建立和实施 ISMS（包括其操作和控制）； b) 维护和持续改进 ISMS。 资源可包括： a) 人；

表A.2 (续)

	b) 的专业技能或知识; c) 组织infrastructure (e.g. buildings、通信线路等); d) 技术; e) 信息、与信息 and 信息处理设施相关的其他资产; f) 钱(例如。现金、流动证券和信用额度)。
审计实践指南	审计员应确认该组织预期、确定和分配建立和实施ISMS所需的资源(包括其操作和控制), 以及其维护和持续改进所需的资源。
支持文档	ISO 31000: 2018, 4.3.5
A.4.2能力 (ISO/IEC27001: 2013、7.2)	
相关ISO/ IEC 27001 从句	ISO/IEC 27001: 2013, 5.3, 7.1, 7.5.1注释, 9.1d) 和e), 9.2e)
相关 ISO/IEC 27000 定义	能力、有效性
审计证据	审计证据可通过文件化信息或其他相关信息获得: a) 的组织角色、职责和权限; b) 工作描述; c) 要求能力; d) 教育记录; e) 的培训方案、课程和教育活动; 为获得和保留必要的的能力所采取的行动的f) 记录; g) 评价其有效性。 ISO/IEC 27001: 2013, 7.2将其职权范围扩大到非本组织成员的人。该要求规定了他们正在“做工作”在本组织的控制下”。例如, 可以包括分包商和志愿工人。 向第三方要求的审计证据应限于为ISMS组织执行的职能和活动的证据
审计实践指南	审计员应确认该组织: a) 决定: 1) 从事在其控制下工作并影响其信息安全绩效的人员; 2) 为人员达到预期结果的知识 and 技能; 3) 该人员应用知识和技能以达到预期结果的能力; b) 确保这些人有能力基于适当的教育、培训或经验的能力; c) 在适用的情况下, 采取行动以获得必要的的能力, 并评估所采取行动的有效性。
支持文档	ISO/IEC 27003:2017, 7.2 ISO/IEC27021: 2017, 附录A
A.4.3意识 (ISO/IEC27001: 2013、7.3)	

表A.2（续）

相关ISO/ IEC 27001 从句	ISO/IEC 27001:2013, 5.1 d), 5.2, 9.1, 9.2, 10.1, 10.2
相关 ISO/IEC 27000 定义	符合性、有效性、绩效、政策性
审计证据	审计证据可以通过有文件化的信息或其他关于信息安全政策的信息来获得； b)信息安全目标； c)信息安全性能； d)不合格项和纠正措施； e)的组织角色、职责和权限； f)工作描述； 适用的g)意识方案和培训材料。
审计实践指南	审计员应确认，在本组织的控制下从事工作的人员知道： a)的信息安全策略； b)他们对ISMS的有效性的贡献，包括提高信息安全性能的好处； c)：不符合ISMS要求的含义。 审计员应采访适当数量的人作为抽样，以确认他们了解这些信息。 对政策的认识不应意味着需要记住； 相反，人们应该了解关键的政策承诺及其在实现这些承诺方面的作用。 审计员也可以找到信息安全意识的证据 不致力于信息安全的培训计划。这些活动可以与高层管理人员的沟通活动密切相关[ISO/IEC 27001: 2013, 5.1 d]和7.4]。
支持 文档	ISO/IEC 27003:2017, 7.3
A.4.4通信（ISO/IEC27001：2013, 7.4）	
相关ISO/ IEC 27001 从句	ISO/IEC 27001:2013, 5.1, 5.2, 5.3, 6.2, 9.2
相关 ISO/IEC 27000 定义	政策
审计证据	审计证据可以通过有文件化的信息或其他关于信息安全政策的信息来获得； b)的组织角色、职责和权限； c)的信息安全风险评估流程； d)的信息安全风险处理流程； e)信息安全目标； 说明流程已按计划进行的f)信息； g)是信息安全风险评估的结果； h)的信息安全风险处理结果； ISMS的i)性能； j)审计结果

表A.2 (续)

	k) 管理评审的结果。
审计实践指南	审计员应确认组织的沟通需求，按照ISO/ IEC 27001的通信要求有效地实施和维护。 证据的例子可以包括 a) 的答案被记录在会议记录中，或者 b) 是一个正式的沟通计划，文件化的程序和结果，或 c) 采访被分配到特定角色的人，以证明他们知道与他们的角色相关的沟通，关于什么、什么、何时、谁沟通，谁有这种沟通的权力，以及沟通是如何受到影响的过程。 这些证据可作为补充： a) 在以下系统上的通信信息如下： 1) 对有效的信息安全管理符合信息安全管理要求的重要性； 2) 政策； 3) 的职责和权限； - ISMS的4) 性能； 5) 目标 6) 对ISMS的有效性的贡献，包括改进性能的好处； - 不符合ISMS要求的7) 影响； 8) 审计结果； b) 是一个正式的沟通计划，有记录的程序和结果。 审计员应核实该组织是否已确定其与ISMS有关的沟通的需要。例如，这些措施可以包括透明度、适当性、可信度、响应性、清晰性和保护性。 交流可以是口头的或书面的，单向的或双向的，内部的或外部的。
支持文档	ISO 31000: 2018, 4.3.6, 4.3.7 ISO/IEC 27003:2017, 7.4
A.4.5 文件化信息 (ISO/IEC27001: 2013, 7.5)	
A.4.5.1 通用版 (ISO/IEC 27001: 2013, 7.5.1)	
相关ISO/IEC 27001从句	ISO/IEC27001: 2013、4.3、5.2 e), 6.1.2, 6.1.3, 6.2, 7.2d), 8.1, 8.2, 8.3, 9.1, 9.2g), 9.3, and 10.1
相关ISO/IEC 27000定义	记录的信息
审计证据	审计证据可以通过文件化信息或在ISMS中创建、控制和/或维护的其他信息获得，包括： a) 管理体系的范围； b) 政策； c) 目标； d) 能力的证据； 为管理系统的规划和运行所需的外部来源的e) 信息；

表A.2（续）

	f) 信息安全风险评估流程； g) 信息安全风险处理流程； h) 适用性声明； 必要的i) 信息，以确保流程和确定的控制已按计划执行； 信息安全风险评估的j) 结果； 信息安全风险处理的k) 结果； l) 的监测、测量、分析和评价结果； m) 内部审计方案及其实施情况的证据； n) 内部审计结果； o) 管理评审结果； p) 不符合项的性质和所采取的行动 q) 纠正措施结果。 可以使用最初为满足ISO/IEC27001要求以外的目的而创建的文档化信息。
审计实践指南	审计员应确认该组织的ISMS包括： ISO/IEC 27001所要求的a) 文件化信息； b) 记录了由组织确定的对ISMS的有效性所必需的信息。 “记录信息作为…的证据”意味着前一个术语“记录”。 审计员应确认，该组织决定了什么已记录的信息- 如果它需要超过ISO/IEC 27001明确要求的效率- 其ISMS的独立性。它应考虑的因素列在审计证据行中。 术语“文件化信息”是指ISO/IEC 27001确定需要控制和以任何格式或介质进行维护的信息（见ISO/IEC 27001：2013, 7. 5. 3）。 审核员应确认文件化信息是根据ISO/IEC 27001：2013, 7. 5. 2和7. 5. 3的要求创建和控制的。
支持文档	ISO 31000：2018, 5. 7 ISO/IEC 27003:2017, 7. 5. 1
A. 4. 5. 2创建和更新（ISO/IEC 27001：2013, 7. 5. 2）	
相关ISO/执行27001从句	ISO/IEC 27001:2013, 4. 3, 5. 2e), 6. 1. 2, 6. 1. 3, 6. 2, 7. 2d), 8. 1, 8. 2, 8. 3, 9. 1, 9. 2g)、9. 3和10. 1
继电器ISO/IEC 27000定义	记录的信息
审计证据	审计证据可以通过文件化的信息或其他信息获得。共同属性，允许清晰和独特的识别； b) 格式和所使用的媒体； c) 上次审核或更新的日期； d) 变化的历史； 审核人和审批人的e) 身份。
审计实践指南	审计员应确认，在创建和更新有文件记录的信息时，组织应确保适当的 a) 标识和描述（e. g. a标题、日期、作者或参考编号）； b) 格式(例如。语言、软件版本、图形版本)和媒体等。电子纸) c) 审查和批准的适用性和适当性的文件化信息。

表A.2 (续)

	注13用于文件化信息的标识、格式和媒体为选择实施ISO/IEC27001的组织；它不需要采用文本格式或纸质手册的形式。 审计员应抓住机会执行这些审计任务 ISMS范围内的信息提交给审计。它们不需要每次都执行，只有足够的数量来确认符合ISO/IEC 27001：2013, 7. 5. 2.
支持文档	ISO/IEC 27003:2017, 7. 5. 2
. 5. 3A. 4文件化信息的控制 (ISO/IEC 27001: 2013, 7. 5. 3)	
相关ISO/IEC 27001从句	ISO/IEC 27001: 2013, 4. 3, 5. 2e), 6. 1. 2, 6. 1. 3, 6. 2, 7. 2d), 8. 1, 8. 2, 8. 3, 9. 1, 9. 2 g)、9. 3和10. 1
相关ISO/IEC 27000定义	记录的信息
审计证据	审计证据可以通过有关以下活动的文件化信息或其他信息来获得： a)的分发、访问、检索和使用； b)的存储和保存，包括保存b)的易读性； c)控制的变化(例如。版本控制 d)保留和处置； 文档化信息库的e)结构和配置。
审计实践指南	审核员应确认ISMS和ISO/ IEC 27001所要求的文件化信息受到控制，以确保： a)，适合在需要时使用； b)，它得到了充分的保护(例如。因失去保密性、不当使用或失去完整性而产生的损失) 审计员应确认组织处理下列活动： a)的分发、访问、检索和使用； b)存储和保存，包括保存易读性（数字或其他格式或手写）； c)控制的变化(例如。版本控制 d)保留和处置。 审计员应抓住机会执行这些审计任务 ISMS范围内的信息提交给审计。它们不必每次都执行，只有足够的数量来确认符合ISO/IEC 27001：2013, 7. 5. 3。
支持文档	ISO 31000: 2018, 5. 7 ISO/IEC 27003:2017, 7. 5. 3
. 5a操作 (ISO/IEC27001: 2013, 第8条)	
A. 5. 1运行规划和控制 (ISO/IEC 27001: 2013, 8. 1)	
相关ISO/IEC 27001从句	ISO/IEC 27001: 2013, 4. 4, 6. 1. 1, 6. 1. 2, 6. 1. 3, 6. 2, 7. 5. 1, 9. 1, and 9. 2
相关ISO/IEC 27000定义	结果，信息安全、目标、组织、外包、流程、需求

表A.2（续）

审计证据	审计证据可以通过有文件化的信息或其他信息来获得 a) 需要让组织有信心，确保操作控制过程已经按照计划执行，并被创建和控制（ISO/IEC 27001：2013, 8.1） 由本组织确定为ISMS有效性所必需的b) [ISO/IEC 27001：2013, 7.5.1 b]]； c) 关于ISMS的规划（ISO/IEC 27001：2013, 6.1.1）； 关于信息安全目标的d)（ISO/IEC27001：2013, 6.2）。
审计实践指南	审计员应确认组织的计划、实施和控制 满足组织运营范围内的信息安全要求所需的流程，以确保满足ISO/IEC 27001的要求，并解决优先风险和机会。 审计员应确认操作控制包括为确保业务操作和活动而实施的方法和信息安全控制或设备符合规定的条件、性能标准或法规 合规限制，从而有效地实现ISMS的预期结果。这些控制建立了必要的技术需求，以实现业务流程所需的最佳功能，如技术规范或操作参数或规定的方法。 应对与业务流程相关的需要进行操作控制和信息安全控制的情况进行审查 缺乏操作控制和信息安全控制可能会导致 偏离政策和目标或构成不可接受的风险。这些情况可能与业务操作、活动或流程、生产、安装或服务、维护或承包商、供应商或供应商有关。所实施的控制程度将取决于许多因素，包括所执行的功能、它们的重要性或复杂性、偏差或变化的潜在后果，或所涉及的技术能力与可用的技术能力相比。 因此，审计员应核实该组织： a) 实施了“应对风险和机遇的行动”中确定的行动（ISO/IEC 27001：2013, 6.1）； b) 实施实现信息安全目标中确定的信息安全目标的计划，并实施实现这些目标的计划（ISO/IEC 27001：2013, 6.2）； c) 创建和控制需要信心的文件，以确保操作控制过程和信息安全控制已经按照文件信息的要求进行（ISO/IEC 27001：2013, 7.5）； d) 控制计划中的变更，并审查意外变更的后果，以防止或以其他方式尽量减少技术要求不被满足或引入新的风险的可能性； 当操作控制失败时，e) 会采取必要的措施来解决任何由此产生的不良影响； f) 确保外包过程被确定和控制，i. e. applies考虑操作的控制，这样控制的程度可以限于部分控制或影响，而不打算改变与执行外包过程的外部实体的任何法律关系。
支持文档	ISO/IEC 27003:2017, 8.1
A. 5. 2信息安全风险评估（ISO/IEC27001：2013、8.2）	
相关ISO IEC 27001从句	ISO/IEC 27001:2013, 6.1.2

表A.2 (续)

相关ISO/IEC 27000定义	信息安全
审计证据	审计证据可以通过文件信息或其他关于ISMS计划（ISO/IEC 27001: 2013, 6.1.1）获得； b)信息安全风险评估流程（ISO/IEC 27001: 2013, 6.1.2）； c)信息安全风险评估的结果（ISO/IEC 27001: 2013, 8.2）； d)的适用性声明； e)的风险治疗计划。
审计实践指南	审核员应确认（ISO/IEC 27001: 2013, 6.1）中定义和应用的信息安全风险评估过程已实施并整合到机构操作中，并在计划的时间间隔或发生重大变化时执行，考虑到ISO/IEC 27001: 2013, 6.1.2 a)中建立的标准。 审计员应评估： a)执行风险评估的计划时间间隔适用于ISMS； b)当ISMS（或其上下文）或信息安全事件发生任何重大变化时，该组织将确定哪些变化或事件需要进行额外的信息安全风险评估，以及如何触发这些评估。 有关更多信息，请参见A.3.1.2的审计实践指南。
支持文档	ISO 31000: 2018, 5.4.1 ISO/IEC 27003:2017, 8.2 ISO/IEC 27005
A.5.3信息安全风险处理（ISO/IEC27001: 2013、8.3）	
相关ISO/IEC 27001从句	ISO/IEC 27001: 2013, 6.1.3, 附件A
相关ISO/IEC 27000定义	控制、控制目标、文件化信息、信息安全、残余风险、风险评估、风险标准、风险所有者、风险处理
审计证据	审计证据可通过文件化信息或其他信息获得： 针对ISMS的a)规划； b)的信息安全风险处理流程； c)的风险治疗方案； d)是信息安全风险处理的结果； e)的适用性声明。
审计实践指南	审核员应确认信息安全风险处理流程并应用于“规划ISMS”（ISO/IEC27001: 2013, 6.1）被实施并集成到组织运作中，并在信息安全风险评估过程的每次迭代（ISO/IEC27001: 202013, 8.2）之后执行，或当（部分）风险处理的实施已经失败。 有关更多信息，请参见A.3.1.3的审计实践指南。
支持文档	ISO 31000: 2018, 5.5 ISO/IEC 27003:2017, 8.3 ISO/IEC 27005
A.6性能评估（ISO/IEC27001: 2013, 第9条）	
A.6.1监测、测量、分析和评估（ISO/IEC27001: 2013、9.1）	

表A.2（续）

相关ISO/ IEC 27001 从句	ISO/IEC 27001:2013, 5.3 b), 6.1.1e), 6.2
相关 ISO/IEC 27000 定义	持续改进、有效性、度量、监控、性能、信息安全事件、信息安全事件、信息需求、度量
审计证据	审计证据可以通过关于监测、测量、分析和评估结果的文件化信息或其他信息来获得（见ISO/IEC 27001:2013, 9.1）。 证据也可以通过文件化信息或其他信息获得以下信息： 在相关职能和级别上的a)信息安全目标； b)规划如何实现信息安全目标； c)信息安全目标实现的状态和程度； d)向高层管理人员报告ISMS绩效的情况[参见ISO/IEC 27001:2013, 5.3 b)]； 风险评估的e)结果及风险治疗方案的状态； f)进行监测、测量、分析和评价的方法； g)内部审计计划和审计结果； h)管理评审(s)和管理评审结果； i)信息安全事件报告（见ISO/IEC 27001:2013, A.16.1.2）； j)信息安全缺陷报告（见ISO/IEC 27001:2013, A.16.1.3）； k)信息安全事件报告（见ISO/IEC 27001:2013, A.16.1.4）。
审计实践指南	审计员应确认该组织具有： a)评估了其ISMS的信息安全性能和有效性； b)因此确定： 1)应监测和测量的内容（定性和定量），包括信息安全过程和控制； 2)是监测、测量、分析和评价的方法，如适用的，以确保结果有效； 3)，即在进行监测和测量时进行3)； 执行监测和测量的4)； 5)时，需要对监测和测量的结果进行分析和评估； 6)，他对这些结果进行分析和评估。 审核员应该使用文档化的方法来审查信息安全性能信息如证据，如计划、对最高管理人员的内部管理系统绩效报告、管理审查结果、内部审计报告和信息安全事件、弱点事件报告。 审计员应评估预测、检测、处理错误、报告和报告不符合、信息安全漏洞和其他事件的程度 编址的审计员应确定组织是否以及如何评估应对风险和机会的行动的有效性，以确保在风险处理中确定的信息安全控制得到有效实施并投入使用。

表A.2（续）

	审计员还应评估对信息安全绩效的评估被用来推动ISMS的持续改进。审计员也应予以确认在结果中要考虑的变化（ISO/IEC27001：2013、8.1和8.2）已反映在风险评估过程和风险处理过程中。此外，审计员应确认与处理风险和机会的行动相关的文件信息已更新。 审计员应该审查被监测的特征的信息或测量、分析和评估是必要和充分的，足以判断ISMS计划活动的实现程度和计划成果的实现程度。审核员应确认，通过监测或测量、分析和评估获得的信息已按照管理评审的要求提交给最高管理层（ISO/IEC 27001：2013, 9.3）。 注14如果一个组织遵循ISO/IEC27004中提供的指导，除了“信息需求”外，它还可以使用术语“绩效衡量”和“有效性衡量”。
支持文档	ISO/IEC 27004
A.6.2内部审核（ISO/IEC27001：2013、9.2）	
相关ISO/IEC 27001从句	ISO/IEC 27001:2013, 9.3
相关ISO/IEC 27000定义	审计、审计范围、能力
审计证据	审计证据可通过文件化信息或其他信息获得： a) 一个内部审计计划； b) 内部审计计划； c) 内部审计结果； 内部审计师的d) 能力； e) 管理评审的结果。
审计实践指南	注15本款提供外部审计或自检或同行评估指导。 审计员应确认组织计划、实施和维护内部审计计划，以提供ISMS是否符合ISO/IEC 27001要求和组织自身与ISMS相关的其他要求的信息，以及ISMS正在按计划有效实施和维护。 审计员应核实内部审计方案是否如下： a) 内部审核是根据被审核的过程的重要性和以前审核的结果进行计划和安排的； b) 建立了计划和进行内部审计的方法； 通过考虑到内部审计过程的完整性和独立性，分配了审计方案中的c)角色和职责； d) 制定每个计划的审核目标、审核准则和审核范围； e)，它旨在提供信息，以确认ISMS符合： 1) 符合ISO/IEC27001的要求； 2) 是本组织自身的要求； f) 旨在提供信息，以确认ISMS的有效实施和维护。

表A.2 (续)

	一个审计准则的一个例子是一个参考文献。政策、程序和要求)，并与相关和可核实的记录、事实陈述或其他信息进行比较。审计范围可以包括对物理位置的描述— 措施、组织单位、活动和过程，以及有关审计所涵盖的时间段。 审计员应确认内部审计计划和审计计划已完成 并由内部人员进行实施和维护，或由外部人员进行管理 代表本组织行事的人员。在任何一种情况下，审计人员应确认负责管理内部审计方案的人员和进行内部审计的审计人员符合能力（见ISO/IEC27001：2013、7.2和9.2）要求和指导方针（见ISO/IEC27001：2013、7.2）。 审计员应确认内部审核的结果已报告给负责被审核的职能/单位的管理层和任何其他被视为美联社的个人— 符合通信要求（ISO/IEC27001：2013.7.4）。审计员应确认，有关内部审计结果的信息，包括审查趋势，已按照管理审查的要求进行审查 （见ISO/IEC27001：2013、9.3）。
支持文档	这个document，i.e. ISO/IEC 27007 ISO/IEC TS 27008 ISO/IEC17021-1:2015, 9.3.1.2.2g), 9.3.1.3e), 9.4.8.3a), 9.6.2.2a) ISO/IEC 27006:2015, 9.1.5.1, 9.3.1.2.2 h), 9.5.1, 9.6.2.1.1a)
A. 6.3管理评审（ISO/IEC27001：2013、9.3）	
相关ISO/IEC 27001从句	ISO/IEC 27001：2013, 4.1, 4.2, 8.1.2, 8.1.3, 9.1, 9.2, 10.1, and 10.2
相关ISO/IEC 27000定义	持续的改进，有效性，性能
审计证据	审计证据可通过文件化信息或其他信息获得： a) 按计划的时间间隔进行审查； b) 从以往管理评审中的行动状态； 与ISMS相关的外部 and 内部问题的c) 变化； d) 对信息安全绩效的反馈，包括不符合项和纠正措施的变化趋势、监测和测量结果、审计结果和信息安全目标的实现情况； 来自利益相关方的e) 反馈； 风险评估的f) 结果及风险治疗方案的状态； g) 持续改进的机会。
审计实践指南	审计员应确认最高管理人员已按照计划的审查时间表进行了管理审查，审查所涵盖的信息，并提供预期的产出。 审计人员应该通过审计来评估最高管理人员的个人身份 参与这次审查，实施这一机制来推动ISMS的变化，并指导持续改进的优先事项，特别是在组织背景中不断变化的问题、偏离预期结果或提供有利结果的有利条件方面。 审计人员应核实管理审查是否考虑A. 6.3审计证据中列出b) 至g) 的所有项目。 审计员还应确认，管理审查的产出包括与持续改进机会和对ISMS变更的任何变更需要有关的决定。
A. 7改进（ISO/IEC27001：2013，第10条）	
A. 7.1不符合项和纠正措施（ISO/IEC27001：2013、10.1）	

表A.2 (续)

相关ISO/ IEC 27001 从句	ISO/IEC27001:2013, 7.5, 8.1, 10.2
相关 ISO/IEC 27000 定义	纠正措施、纠正措施、有效性、不合格性
审计证据	审计证据可通过文件化信息或其他信息获得： a) 检查不符合项的性质和随后采取的任何行动； b) 的任何纠正措施的结果； c) 监测和测量结果； d) 审计计划和审计结果； e) 是管理评审的结果； f) 与信息安全相关的利益相关方的要求； g) 由纠正措施带来的ISMS变更。
审计实践指南	审计员应确认： a) 当ISO/IEC 27001和ISMS（包括操作）要求不满足时，组织通过发现不符合项并要求采取纠正措施来响应； b) 不符合和纠正措施包括采取行动纠正情况，检查原因，并确定其他地方是否存在或可能存在于其他事件，以便采取行动防止再次发生； c) 该组织的回应包括评估为确认达到预期结果所采取的行动，以及评估ISMS，以确定是否需要进行更改，以避免未来发生类似的不符合项； 关于不符合项、纠正措施和结果的d)文件是根据文件化信息的要求创建和控制的（见ISO/IEC 27001: 2013, 7.5）。
支持 文档	
A.7.2持续改进（ISO/IEC27001: 2013、10.2）	
相关ISO/ IEC 27001 从句	ISO/IEC27001:2013, 5.1, 5.2, 6.1, 6.2, 7.1, 8.1, 9.1, 9.2, 9.3, 10.1
相关 ISO/IEC 27000 定义	持续的改进，有效性，性能
审计证据	审计证据可通过文件化信息或其他信息获得— 关于： a) 不符合项的性质和随后采取的任何行动，包括报告纠正措施； b) 的任何纠正措施的结果； c) 监测和测量结果； d) 审计计划和审计结果； e) 是管理评审的结果； f) 与信息安全相关的利益相关方的要求； g) 对信息安全事件和突发事件的评估和决策（见ISO/IEC 27001: 2013, A.16.1.4）。
审计实践指南	审计员应确认该组织开展其经常性活动，以提高ISMS的适宜性、充分性和有效性的可衡量结果。

表A.2（续）

	审计员应审查和验证持续改进涉及到做出改变ISMS的设计和实施，以改善器官-化企业实现符合ISMS要求并满足其目标和政策承诺的能力。 审计员应通过审计方式确认该组织： a) 开发了一个实现来实现这一改进，包括但不限于： 1) 采取措施应对风险和机遇（见ISO/IEC 27001：2013, 6.1） 2) 确定目标（见ISO/IEC27001：2013, 6.2）； 3) 升级操作控制（见ISO/IEC 27001：2013, 8.1），并进入考虑新的技术、新方法或新信息； 4) 性能分析和评估（见ISO/IEC27001：2013, 9.1）； b) 进行内部审核（见ISO/IEC27001：2013、9.2）； c) 进行管理评审（见ISO/IEC27001：2013、9.3）； d) 检测不符合项(e)和其他纠正措施(s)（见ISO/IEC27001：2013, 10.1）； e) 根据监测、测量、分析和评估（ISO/IEC 27001：2013, 9.1）和内部审核（ISO/IEC27001：20101、9.2）和管理评审（ISO/IEC27001：9.3），确定改进机会，并根据应对风险和机遇(ISO/IEC 27001：2013, 6.1）、目标和计划（ISO/IEC27001：2013, 6.2）和运营规划和控制（ISO/IEC27001：2013, 8.1）。
--	--

参考书目

- [1] ISO/IEC 170211: 2015, 合格评定—提供管理体系审核和认证机构的要求第1部分：要求
- [2] ISO/IEC 17024, 合格评定—人员认证机构的一般要求
- [3] ISO/IEC 27001: 2013, 信息技术。安全技术。信息安全管理系统。要求
- [4] ISO/IEC 27002, 信息技术。安全技术。信息安全控制的实施规范
- [5] ISO/IEC 27003: 2017, 信息技术安全技术信息安全管理系统。指导
- [6] ISO/IEC 27004, 信息技术。安全技术。信息安全管理系统。监视、测量、分析和评价
- [7] ISO/IEC 27005, 信息技术。安全技术。信息安全风险管理
- [8] ISO/IEC 27006: 2015, 信息技术—安全技术—提供审计和认证的机构的要求
- [9] ISO/IEC 27008, 信息技术。安全技术。信息安全控制评估指南
- [10] ISO/IEC 27021: 2017, 信息技术——安全技术——信息安全管理系统专业人员的能力要求
- [11] ISO 31000: 2018, 风险管理—指南
- [12] IAF MD1, 2018, IAF对由多站点组织运营的管理系统进行审计和认证的强制性文件，国际认证论坛。[浏览于2019年01-01年]。可在 https://www.iaf.org/articles/Mandatory_documents/38

此页已故意留下空白。